

Security Hardening Guide

RBAC enforcement, internal service port exposure, leaked git history, the Wazuh Indexer credential mismatch, and the host firewall (§3) have all been remediated — see Document 8 for the full log. Credential rotation (§1) remains the top open item.

1. Credential Rotation (do first)

Service	Current Default	Action
PostgreSQL	sop_admin / changeme	Rotate; move to Docker secrets or an external manager, not plaintext compose.yml
MinIO	sop_admin / changeme123	Rotate root; scoped access keys per consumer instead of shared root
Grafana	admin / admin123	Rotate on first login; enable Grafana's own RBAC instead of shared admin
n8n	admin / changeme123	Rotate basic-auth; consider fronting with Keycloak/OIDC
Wazuh API	wazuh / WazuhApi123!	Rotate API_PASSWORD in the manager env + backend env var together
Wazuh Indexer	admin / SecretPassword1	Rotate; update filebeat.yml + backend WAZUH_INDEXER_PASSWORD in sync
Keycloak Admin	admin / admin123	Rotate immediately — this account can create/modify every realm and user

2. Identity & Access

- Disable Keycloak start-dev before real production traffic — switch to start with hostname, TLS, and production DB tuning.
- Enforce MFA for all analyst/admin roles in the soc-platform realm (TOTP/WebAuthn).
- DONE for asset/org delete — extend require_role to remaining destructive endpoints (case actions, agent triggers) that still only check token validity.
- Add user-attributed audit logging to state-changing endpoints — the JWT already carries preferred_username / sub, it just isn't logged today.
- Rotate JWT signing keys periodically via Keycloak's realm key rotation policy; JWKS caching with refresh-on-miss already handles rollover transparently.

3. Network & Edge

- Disable Traefik's insecure API/dashboard (--api.insecure=true, port 8081) or restrict to VPN/localhost — currently reachable without auth.
- Extend rate-limiting beyond the backend router to frontend and n8n routers.

- Restrict the n8n IMAP trigger to a known mailbox or add SPF/DKIM verification before trusting extracted IOCs.
- DONE — ufw enabled, default-deny incoming, only 22/80/443 allowed; internal service ports also removed from docker-compose.yml.

4. Data Layer

- Enable Elasticsearch security (currently xpack.security.enabled=false) — auth + TLS to the backend, even internally.
- Enable TLS for Postgres and Redis connections between containers, not just at the edge.
- Scope MinIO access keys per-purpose rather than one shared root credential.
- Encrypt backups at rest once the DR backup cadence (Document 6) is implemented, especially MinIO evidence/sample mirrors.

5. AI Layer

- Add input length limits and prompt-hardening to reduce prompt-injection risk from attacker-controlled fields.
- Default to local Ollama for data with strict residency/confidentiality requirements — cloud providers receive prompt content off-premises.
- Monitor soc_ai_request_failures_total in Grafana for anomalous spikes (revoked key, or injection causing malformed prompts).

6. Container & Host Security

Item	Guidance
Falco (privileged, pid: host)	Required for syscall visibility; keep patched, pin to a specific version tag
Suricata/Zeek (NET_ADMIN/NET_RAW)	Required for packet capture; scope to minimum capabilities where possible
Docker socket mounts (Falco, Promtail)	Both mount /var/run/docker.sock — a compromise has host-level blast radius; keep images minimal and patched
Image tags	Several services use :latest — pin explicit version tags before production

7. CI/CD & Supply Chain

The current .github/workflows/ci.yml and backend/tests/ cover linting and unit tests. Remaining scanning stages to wire as required/blocking (not just warning) steps:

- Trivy — container image vulnerability scanning before push
- Gitleaks — secrets detection on every commit/PR
- OWASP Dependency-Check — dependency vulnerability scanning (requirements.txt, package.json)
- SAST — static analysis on the FastAPI backend and Next.js frontend
- Cosign — sign built container images before deployment

- Syft — generate SBOMs for backend and frontend images

8. Ongoing Practices

- Weekly: review Grafana's Threat Verdicts Breakdown and Incidents Created dashboards.
- Rotate all API keys on a fixed schedule (e.g. 90 days) and immediately on suspected compromise.
- Periodically review Keycloak realm roles, remove stale analyst accounts.
- Quarterly: run the DR restore drill (Document 6 §5) to confirm backups are restorable.
- Re-run the STRIDE analysis (Document 2) whenever a new integration or public-facing route is added.